SECURITY AND PRIVACY POSTURE

What we built — and what we have not claimed.

Plain language for IT and quality. Pharma QMS is self-hosted pilot software. It is not a validated / Part 11 system.

Controls present in the product

Hosting	You run the stack. Postgres holds plant data. Default desktop bind is loopback (`127.0.0.1`).
Actors	Demo mode uses a role selector that trusts client identity headers — walkthroughs with synthetic data only. Strict mode (operator-enabled) requires argon2id password login, optional TOTP, optional OIDC single sign-on, server-side sessions and password re-entry for approvals. No SAML.
Audit	Append-only application audit events in a verifiable hash chain with review-by-exception. Tamper-*evident* at application level; **not** WORM storage and not an independent security assessment.
Transport	Operator-controlled TLS at the edge you choose (compose / k3s ingress). Desktop pilot often uses plain HTTP on localhost.

Explicit non-claims

Validation	Not validated. Not 21 CFR Part 11, EU GMP Annex 11, or WHO computerized-systems certified.
Gateways	No live CDSCO SUGAM, FDA ESG, EMVS, or E2B exchange.
Pen test	No independent penetration test published yet.
Retail	Not Zyvora Pharmacy (retail medical stores).
Data	Built and demonstrated with synthetic / pilot data.

Report a vulnerability

security@zyvor.dev — please do not open public issues with exploit detail.

Intended use

See docs/INTENDED-USE.md on the public site for the full boundary statement.

Read this before a pilot. If your quality unit needs Part 11 evidence packs, those are a customer validation programme — not something this PDF or the software asserts.